Semana 03 — Autorizacion con limites verificables

Grupo 2 · rol Azul · ejemplo de trabajo

Prof. César Rodríguez | ELECTRONICA | 1 de noviembre de 2026

Curso	CYBERSEGURIDAD — Ciberseguridad Aplicada
Semana	03 de 10
Fase	1 — Fundamentos, criptografía y marco legal
Grupo	2
Rol	Azul
Entrega	GitHub, carpeta semana_03/
Corte	Domingo 23:59 de la semana correspondiente; lo posterior no se corrige.

1 Tu rol en la práctica

Parte de su propia captura cruda y aplica el control equivalente: configuración, parche o regla de red. Repite el ataque para demostrar que falla y documenta el antes y el después.

- Leer su propia evidencia cruda y elegir el control que corta el ataque en el punto más barato.
- Aplicar el control y repetir el ataque para demostrar que ya no funciona.
- Documentar el antes y el después con los mismos comandos y la diferencia medida.

2 Qué aporta este rol al entregable

La mitigación aplicada, el comando de verificación y la comparación de resultados.

3 Ejemplo paso a paso

El rol Azul escribe la autorizacion pensando en como se comprueba: tasas maximas, herramientas permitidas y un plan de vuelta atras. Una autorizacion sin limites medibles no protege a nadie.

3.1 Declarar herramientas y tasas permitidas

La tasa se declara antes de medir y se aplica en el comando. Si el escaneo tarda mas, es correcto: el limite manda sobre la prisa.

```
mkdir -p semana_03/evidencia
nmap --version | head -1 > semana_03/evidencia/herramientas.txt
nmap -sT -p 8081,3000,2222 --max-rate 20 127.0.0.1 \
  -oN semana_03/evidencia/roe_scan.txt
grep -E 'Nmap scan report|Not shown|elapsed' \
  semana_03/evidencia/roe_scan.txt
```

3.2 Fijar el plan de vuelta atras

Antes de tocar configuracion se guarda el estado que permite restaurarla. Si el servicio no arranca despues del cambio, ese archivo es la unica salida.

```
docker exec objetivo-web cp /etc/apache2/apache2.conf \
  /tmp/apache2.conf.bak
docker exec objetivo-web sha256sum /tmp/apache2.conf.bak \
  > semana_03/evidencia/rollback.sha256
```

3.3 Definir criterios de parada

Se declaran tres detenciones: datos personales, indisponibilidad de un servicio y hallazgo que permita acceso fuera del alcance. Cada una tiene quien decide y como se comunica.

3.4 Verificar que la autorizacion cubre lo que se ejecuta

Se compara comando por comando con el alcance. Lo que no esta cubierto no se ejecuta, aunque parezca inofensivo.

3.5 Limite declarado y como se verifica

Limite declarado y como se verifica

Limite	Valor	Verificacion	Evidencia	Si se incumple
Tasa de sondeo	20 paquetes por segundo	Opcion max-rate del comando	roe_scan.txt	Se detiene y se repite
Intentos SSH	20 por cuenta	Contador del propio script	ssh_intentos.txt	Se aborta la prueba
Servicios objetivo	Solo 8081, 3000 y 2222	Lista de puertos del comando	roe_scan.txt	No se ejecuta
Vuelta atras	Copia previa y hash	sha256sum de la copia	rollback.sha256	Se restaura antes de seguir

La verificacion se hace con una salida del propio comando, no con una promesa en el documento.

4 Qué guardar en el repositorio

La autorizacion incluye herramientas, tasas, criterios de parada y plan de vuelta atras, con una verificacion ejecutada para cada limite.

```
semana_03/
|-- autorizacion.md
|-- informe.md
|-- evidencia/
|   |-- herramientas.txt
|   |-- roe_scan.txt
|   `-- rollback.sha256
`-- README.md
```

- La tasa declarada aparece en el comando y en la salida.
- El plan de vuelta atras se probo al menos una vez sin romper el laboratorio.
- Los criterios de parada nombran quien decide.
- Lo ejecutado no excede lo autorizado, comparado linea por linea.

5 Cómo se corrige

Criterio	Peso
Alcance explícito con inclusiones y exclusiones	3,0
Reglas de enfrentamiento operativas	2,5
Tipificación correcta de las conductas del caso	2,0
Juicio fundamentado sobre admisibilidad de la evidencia	1,5
Código de ética firmado individualmente	1,0
Total	**10,0**

- Un escaneo lento por respetar la tasa no es un fallo de la practica.
- {'Restaurar un servicio modificado cuenta como cambio': 'se documenta el comando.'}

Recuerda

El trabajo es independiente: cada grupo usa su propio repositorio y su propio laboratorio, y la comparación de resultados es en clase. Corte: Domingo 23:59 de la semana correspondiente; lo posterior no se corrige.